

**Modelo de Auditoría de Inteligencia Artificial en Infraestructura Crítica: Una
Propuesta de Alineación Normativa basada en NIST AI RMF 1.0, ISO/IEC
42001:2023 e ISO/IEC 27001:2022**

Daniel Camilo Robles
José David Vargas Martínez
Alejandro Gordillo Gómez

Fundación Universitaria Los Libertadores
Especialización de la información
Metodologías y buenas prácticas de ciberseguridad

Tabla de Contenidos

1. Resumen	4
2. Palabras Claves	4
3. Justificación	5
4. Objetivo	6
4.1. Objetivos específicos	6
5. Alcance	7
5.1. Alcance Temático	7
5.2. Alcance Regulatorio y Geográfico	7
6. Metodología	8
7. Marco teórico	9
7.1. Inteligencia Artificial	9
7.2. Infraestructura Crítica	10
7.3. CONPES 3995 — Política Nacional de Confianza y Seguridad Digital	11
7.4. NIST AI RMF 1.0 — Framework de Gestión de Riesgos de IA	12
7.5. ISO/IEC 42001:2023 — Sistema de Gestión de Inteligencia Artificial	13
7.6. ISO/IEC 27001:2022 — Seguridad de la In formación	14
8. Escala de Valoración	15
9. Análisis	15
9.1. ¿Por qué estos controles y no otros?	15
9.2. Controles seleccionados - ISO/IEC 42001:2023	16
10. Resultados	19
10.1. El Framework IA-SEC	19
10.2. Lo que dijeron los expertos	21
10.3. Lo que encontramos en cada punto de correlación	21
11. Análisis Final	22
12. Conclusiones	24
13. Definiciones	25
14. Lista de referencias	27

Lista de tabla

Tabla 1 Escala de valoración del Framework IA-SEC	12
Tabla 2 Mapping normativo entre los tres estándares	16

1. Resumen

Este trabajo presenta el Framework IA-SEC, un modelo comparativo de auditoría para sistemas de inteligencia artificial en infraestructura crítica, construido a partir de la correlación de controles del NIST AI RMF 1.0, la ISO/IEC 42001:2023 y la ISO/IEC 27001:2022. A través de un análisis táctico-estratégico se identificaron cinco puntos de intersección entre los tres estándares, consolidados en una matriz de cumplimiento operativa con escala de madurez de seis niveles. El modelo responde a la ausencia de herramientas unificadas de auditoría de IA en Colombia y se alinea con las directrices del CONPES 3995 y 4144 de 2015.

2. Palabras Claves

Seguridad de la información; Ciberseguridad; Auditoría de IA; Ciberseguridad; NIST AI RMF 1.0; ISO/IEC 42001:2023; ISO/IEC 27001:2022; Gobernanza de IA; Infraestructura crítica; Gestión de riesgos de IA

3. Justificación

Durante el desarrollo de este proyecto, el equipo se encontró con una pregunta que nadie parecía estar respondiendo de forma práctica: ¿cómo audita un profesional de seguridad de la información un sistema de IA en un banco o en una clínica colombiana? Hay estándares que hablan de riesgos de IA, otros que hablan de seguridad de la información, y otro que habla de gobernanza de IA, pero ninguno los conecta de manera operativa.

Esa desconexión tiene un costo real. Las organizaciones terminan auditando sus sistemas de IA con los mismos instrumentos que usan para auditar una base de datos o un servidor web, ignorando por completo los riesgos específicos que la IA introduce: el modelo puede estar derivando sin que nadie lo sepa, los datos con que fue entrenado pueden haber sido manipulados, o puede estar siendo atacado de formas que ningún control convencional detectaría.

La propuesta que se presenta en este trabajo nace de esa brecha. La idea fue simple: tomar los tres marcos más relevantes disponibles hoy, el NIST AI RMF 1.0 para la gestión de riesgos, la ISO/IEC 42001:2023 para la gobernanza de IA, y la ISO/IEC 27001:2022 para la seguridad de la información y encontrar los puntos donde se conectan, se superponen y se complementan. De ese cruce surge el Framework IA-SEC, que no es un nuevo estándar, sino una herramienta práctica que ayuda a los auditores a trabajar con los estándares que ya existen de forma integrada y eficiente.

4. Objetivo

Desarrollar un modelo comparativo de auditoría para sistemas de inteligencia artificial (IA) desplegados en infraestructura crítica, mediante el análisis y la correlación cinco controles de cada las normas NIST AI RMF 1.0, ISO/IEC 42001:2023 y la ISO/IEC 27001:2022, con el fin de identificar puntos de intersección, brechas normativas y criterios de cumplimiento aplicables al contexto colombiano.

4.1. Objetivos específicos

- Analizar los marcos normativos del NIST AI RMF 1.0, la ISO/IEC 42001:2023 y la ISO/IEC 27001:2022 para identificar sus estructuras, propósitos y controles más relevantes aplicables a sistemas de inteligencia artificial en infraestructura crítica.
- Correlacionar los controles seleccionados de los tres estándares mediante un proceso de mapping normativo, identificando sus puntos de intersección, traslapes y brechas en el contexto de la gestión de riesgos de sistemas de IA.
- Diseñar el Framework IA-SEC como modelo comparativo de auditoría organizado en dominios operativos auditables, que integre los controles correlacionados en una herramienta aplicable al contexto colombiano.

- Construir una matriz de cumplimiento operativa que traduzca los controles seleccionados en criterios de verificación medibles, con una escala de valoración de madurez para uso del auditor en campo.

5. Alcance

5.1. Alcance Temático

Este trabajo se concentra en construir un modelo comparativo que cruce los controles más relevantes del NIST AI RMF 1.0, la ISO/IEC 42001:2023 y la ISO/IEC 27001:2022, aplicado a sistemas de inteligencia artificial que operen en sectores de infraestructura crítica colombiana. No se limita a un sector en particular: la intención es que el modelo sea lo suficientemente flexible para usarse tanto en una entidad bancaria como en un hospital o una empresa del sector energético.

Conviene aclarar lo que este trabajo no es: no se desarrolla software, no se audita ninguna empresa real y no se propone implementar ninguna herramienta tecnológica. Lo que sí se entrega es una matriz de cumplimiento que cualquier auditor o profesional de seguridad pueda tomar, aplicar y adaptar a su contexto particular.

5.2. Alcance Regulatorio y Geográfico

El modelo se ancla en el contexto colombiano, donde la principal referencia es el CONPES 3995, que traza la hoja de ruta nacional para la seguridad digital y la protección de infraestructuras críticas y lo complementa el CONPES 4144, de la Política Nacional de Inteligencia Artificial de Colombia y representa el primer instrumento de política pública dedicado exclusivamente a la gobernanza, desarrollo y uso responsable de la IA en el país. Su objetivo es generar las capacidades para la investigación, desarrollo, adopción y aprovechamiento ético y sostenible de sistemas de IA,

6. Metodología

El trabajo se desarrolló bajo un enfoque cualitativo y analítico. No se busca medir fenómenos con estadísticas, sino entender cómo tres marcos normativos distintos pueden integrarse en una herramienta útil para los auditores. El proceso se dividió en cuatro fases:

Fase 1- Revisión documental: el equipo revisó en detalle los tres estándares de referencia: el NIST AI RMF 1.0, la ISO/IEC 42001:2023 y la ISO/IEC 27001:2022. El objetivo no era sólo entender qué dice cada uno, sino identificar los riesgos específicos que la IA introduce en entornos de infraestructura crítica (opacidad algorítmica, deriva del modelo y vulnerabilidad adversarial) y reconocer dónde los tres marcos abordan esos mismos problemas con distintos lenguajes y enfoques.

Fase 2 - Selección y correlación de controles: con base en los riesgos documentados en la fase anterior, se seleccionaron los controles con mayor capacidad de cobertura simultánea en los tres estándares. Es importante aclarar que los controles no se eligieron porque encajaran con el NIST, se eligieron por su relevancia frente a los riesgos identificados en los propios marcos normativos, y luego se correlacionaron entre sí mediante un proceso de mapping normativo que permitió identificar los cinco puntos de intersección que fundamentan el Framework IA-SEC.

Fase 3 - Diseño del modelo: con los controles identificados y correlacionados, se construyó el Framework IA-SEC: cuatro dominios operativos que organizan los controles de forma lógica y auditable. Esta fase también incluyó la redacción de criterios de cumplimiento y evidencias sugeridas para cada dominio.

Fase 4 - Validación mediante entrevistas simuladas: para verificar que el modelo era pertinente y usable, se diseñó un instrumento de entrevista estructurada y se aplicó a tres perfiles de expertos simulados: un auditor líder certificado en ISO/IEC 27001:2022, un profesional de ciberseguridad con experiencia en gestión de riesgos de TI, y un responsable de seguridad de una organización del sector energético colombiano.

7. Marco teórico

7.1. Inteligencia Artificial:

La inteligencia artificial (IA) es un campo de la informática que se enfoca en crear máquinas inteligentes que puedan realizar tareas que normalmente requieren inteligencia humana, como aprender, razonar y resolver problemas.

No obstante, en la fase de evaluación y verificación de estos sistemas, se evidencia que la diferencia fundamental de la IA frente al software tradicional no reside en su complejidad técnica. El diferencial real se da en las características inherentes a su operatividad que imponen desafíos para los procesos de auditoría. Para efectos de este análisis, dichos factores se conceptualizan como los riesgos fundamentales de la IA:

- **Opacidad algorítmica:** La norma ISO/IEC 42001:2023 en los controles de transparencia y explicabilidad dan sustento a este riesgo que se manifiesta operacionalmente bajo el paradigma de la "caja negra". Alude a la complejidad técnica para descifrar y auditar la lógica interna mediante la cual el modelo

procesa variables. Esto conlleva una pérdida de la trazabilidad sobre el proceso lógico que conduce al sistema a interpretar una respuesta o decisión como óptima.

- **Deriva del modelo (*Model drift*):** en contraste con el código estático, un modelo de aprendizaje automático altamente preciso puede degradar su eficacia si el entorno o los datos de entrada mutan. La IA no presenta fallos binarios ni interrupciones súbitas; su obsolescencia es una degradación silente y evolutiva.
- **Vulnerabilidad adversarial:** ocurre cuando actores externos manipulan el modelo inyectando entradas específicamente alteradas para inducir al error. La criticidad reside en que el sistema ejecuta la acción errónea sin que los controles de seguridad tradicionales detecten la anomalía, configurando una superficie de ataque ajena a la ingeniería de software clásica.

7.2. Infraestructura Crítica:

Pensemos en lo que ocurriría si el sistema de pagos interbancarios de Colombia dejará de funcionar un lunes por la mañana, o si los algoritmos que gestionan la distribución eléctrica de Bogotá comenzarán a tomar decisiones erráticas. El impacto no sería sólo económico: afectaría la vida cotidiana de millones de personas. Eso es exactamente lo que define a la infraestructura crítica: son los sistemas cuya falla tiene consecuencias en cascada que ningún sector puede absorber solo.

El CONPES 3995 identifica como sectores críticos en Colombia el sistema financiero, la energía, la salud, las telecomunicaciones y el transporte. En todos ellos, la inteligencia artificial ya está presente.

7.3. CONPES 3995 - Política Nacional de Confianza y Seguridad Digital

El Estado colombiano cuenta con dos instrumentos de política pública que enmarcan directamente este trabajo. El primero es el CONPES 3995 de 2020, Política Nacional de Confianza y Seguridad Digital, que establece los lineamientos para proteger las infraestructuras críticas digitales del país e identifica como sectores prioritarios el financiero, el energético, la salud, las telecomunicaciones y el transporte. El segundo, y más reciente, es el **CONPES 4144 de febrero de 2025**, Política Nacional de Inteligencia Artificial, que representa el primer instrumento de política pública colombiana dedicado exclusivamente a la IA.

El CONPES 4144 estructura su política en torno a seis ejes estratégicos, de los cuales dos son directamente relevantes para este trabajo:

El primero es el eje de Ética y Gobernanza, que busca fortalecer los mecanismos de gobernanza y aplicar principios éticos relacionados con IA para asegurar un desarrollo y uso responsable, incluyendo el desarrollo de mecanismos de auditoría ética.

El segundo es el eje de Mitigación de Riesgos, que define medidas para la identificación, prevención y mitigación de los riesgos y efectos no deseados relacionados con sistemas de IA, reconociendo la necesidad de generar nuevos lineamientos de seguridad digital específicos para la IA, especialmente en el sector privado.

En el contexto de este trabajo, los dos documentos CONPES cumplen roles complementarios: el CONPES 3995 define el universo de sectores críticos que requieren protección y establece el marco de seguridad digital nacional, mientras que el CONPES

4144 confirma que Colombia reconoce institucionalmente la necesidad urgente de gobernar y auditar sus sistemas de IA y que aún carece de las herramientas para hacerlo.

Motivación y valor diferencial

La pertinencia de este trabajo está respaldada por el propio diagnóstico del Estado colombiano. El CONPES 4144 de 2025 reconoce explícitamente que Colombia carece de un marco formal e institucional de gobernanza para el desarrollo, adopción y aprovechamiento de sistemas de IA, y que existe desconocimiento sobre asuntos relacionados con la seguridad digital en los sistemas de IA que limitan su uso seguro y responsable. Más aún, el documento señala que Colombia ocupa el puesto 54 de 108 países en el Índice de Exposición a la Ciberseguridad y obtuvo apenas 18,66 sobre 100 puntos en la dimensión de capacidades para una IA responsable según el Índice Global de IA Responsable.

7.4. NIST AI RMF 1.0 — Framework de Gestión de Riesgos de IA

En 2023, el Instituto Nacional de Estándares y Tecnología de Estados Unidos publicó el AI Risk Management Framework, más conocido como NIST AI RMF 1.0. No es un estándar de cumplimiento obligatorio, sino una guía voluntaria, y eso es precisamente lo que lo hace valioso: fue diseñado para ser flexible y adaptable a cualquier tipo de organización que use IA.

Su arquitectura se organiza en cuatro funciones que no son pasos secuenciales sino actividades que se retroalimentan constantemente:

GOVERN: es el punto de partida. Antes de hacer cualquier cosa con la IA, la organización necesita tener clara su cultura, sus políticas y quién responde por qué. Sin esto, las otras tres funciones no tienen dónde apoyarse.

MAP: consiste en entender el terreno: ¿para qué se va a usar el sistema de IA?, ¿quiénes pueden verse afectados?, ¿qué puede salir mal en este contexto específico? No es un ejercicio teórico; es la base de cualquier decisión de control.

MEASURE: una vez identificados los riesgos, hay que medirlos. ¿Qué tan robusto es el modelo ante ataques? ¿Qué tan confiable es su comportamiento? Esta función le da números a los riesgos para poder priorizarlos.

MANAGE: con los riesgos medidos y priorizados, toca actuar: implementar controles, monitorear su efectividad y ajustar cuando sea necesario. El ciclo no termina nunca.

En este trabajo, el NIST AI RMF 1.0 actúa como el hilo conductor que da estructura a los controles que se seleccionan de las otras dos normas.

7.5. ISO/IEC 42001:2023 — Sistema de Gestión de Inteligencia Artificial

Hasta 2023, no existía ningún estándar certificable que le dijera a una organización cómo gestionar un sistema de gestión de inteligencia artificial (IA) de forma responsable. La ISO/IEC 42001 llegó a llenar ese vacío. Es el primer estándar de sistema de gestión diseñado específicamente para la IA, y su aparición fue un hito en el campo de la gobernanza tecnológica.

Su estructura le resultará familiar a quien conozca la ISO 27001: sigue el mismo esquema de alto nivel de diez cláusulas, lo que facilita su integración en organizaciones que ya tienen un sistema de gestión de seguridad implementado. La diferencia está en su Anexo A, que contiene 38 controles específicos para un sistema integrado de inteligencia artificial (IA), muy diferentes a los controles de seguridad de la información convencionales.

Lo que hace a esta norma especialmente relevante para infraestructura crítica es que no solo habla de seguridad técnica: exige transparencia en los algoritmos, supervisión humana sobre las decisiones automatizadas y gobernanza de los datos de entrenamiento. Cuando un algoritmo decide si un paciente es prioritario en urgencias o si una empresa puede acceder a financiamiento, estas exigencias dejan de ser requisitos normativos y se convierten en responsabilidades éticas

7.6. ISO/IEC 27001:2022 — Seguridad de la Información

La ISO/IEC 27001 no necesita presentación en el mundo de la seguridad de la información. Es el estándar más adoptado globalmente para la gestión de la seguridad, con decenas de miles de organizaciones certificadas en el mundo. Su valor en este trabajo no es su popularidad, sino algo más práctico: es el lenguaje que ya hablan los auditores.

La apuesta de este trabajo es que esos controles, pensados originalmente para sistemas de información convencionales, pueden extenderse para cubrir los riesgos

específicos de IA. Un control de monitoreo de actividades puede aplicarse a la inferencia de un modelo en producción igual que a los accesos de un usuario humano. Esa extensión es uno de los aportes centrales del Framework IA-SEC.

8. Escala de valoración - Modelo de Seguridad y Privacidad de la Información (MSPI)

Para que el Framework IA-SEC sea verdaderamente útil en campo, necesita una escala que le diga al auditor no solo si un control existe o no, sino en qué punto del camino está la organización. Por eso se adoptó una escala de madurez de seis niveles, desde la ausencia total del control hasta su optimización continua.

La escala utilizada toma como referente los niveles de madurez del **Modelo de Seguridad y Privacidad de la Información (MSPI) del Ministerio de Tecnologías de la Información y las Comunicaciones de Colombia**, que establece lineamientos a las entidades públicas en materia de implementación y adopción de buenas prácticas de seguridad de la información, tomando como base estándares internacionales como la ISO/IEC 27001. Su adopción en este trabajo responde a dos razones: primero, porque es el referente nacional más utilizado por las organizaciones colombianas para medir su madurez en seguridad de la información; y segundo, porque su alineación con estándares internacionales lo hace coherente con los tres marcos normativos que fundamentan el Framework IA-SEC. A continuación, se muestran la escala de valoración definida con base en la fuente consultada:

Nivel	Valor	Descripción
No implementado	0	El control no existe ni ha sido considerado por la organización.
Inicial	1	El control está identificado, pero no ha sido formalizado ni documentado.
Repetible	2	El control está en proceso de implementación, pero aún no es efectivo.
Definido	3	El control está documentado, implementado y conocido por los responsables.
Gestionado	4	El control se monitorea y mide periódicamente con indicadores definidos.
Optimizado	5	El control mejora continuamente con base en evidencia y lecciones aprendidas.

Tabla 1 Escala de valoración del Framework IA-SEC

9. Análisis

9.1. ¿Por qué estos controles y no otros?

Frente a la complejidad que suponen los 38 controles de la ISO/IEC 42001, los 93 de la ISO/IEC 27001 y las múltiples prácticas del NIST AI RMF, el equipo se enfrentó al desafío de determinar, bajo criterios de objetividad, cuáles resultaban prioritarios para la protección de infraestructuras críticas.

La resolución de este interrogante no se halló exclusivamente en la teoría de los estándares, sino en el análisis del comportamiento en entornos productivos reales. En consecuencia, el enfoque se desplazó hacia los riesgos específicos inherentes a la IA en sectores sensibles: la **opacidad algorítmica**, la **deriva del modelo (model drift)**, la **vulnerabilidad adversarial** y la dependencia crítica de la integridad de los datos.

Con este diagnóstico, se procedió a identificar y mapear los controles con mayor capacidad de mitigación transversal. La selección final se consolidó bajo los tres criterios siguientes :

- Cobertura transversal de riesgos en los tres estándares de referencia.
- Aplicabilidad pragmática y directa en sistemas de infraestructura crítica.
- Capacidad de auditoría clara, basada en evidencia objetiva y completamente verificable.

9.2. Controles seleccionados - ISO/IEC 42001:2023

De los 38 controles del Anexo A de la ISO/IEC 42001:2023, se trabajaron cinco que responden directamente a los riesgos identificados:

A.2- Políticas para la IA: sin una política formal que diga cómo se usa la IA en la organización, todo lo demás es construcción sobre arena. Este control exige que esas reglas están escritas, aprobadas y reconocidas.

A.4- Contexto de la organización relacionado con la IA: antes de desplegar cualquier modelo, la organización debe documentar en qué entorno va a operar: quiénes son las partes afectadas, qué regulaciones aplican, qué puede fallar. Es el mapa antes del viaje.

A.5- Liderazgo y ciclo de vida de la IA: la seguridad de un modelo no se garantiza solo cuando sale a producción. Este control exige que cada fase del ciclo de vida — desde el diseño del modelo hasta su retiro — tenga controles definidos y responsables claros.

A.7- Operaciones de IA: cuando el modelo ya está funcionando, hay que gestionar todo lo que lo rodea: los proveedores de librerías, los servicios en la nube donde corre, las dependencias externas. Un fallo en cualquiera de esos elementos puede comprometer el sistema entero.

A.9 - Evaluación del desempeño de la IA: ¿cómo sabe la organización que el modelo sigue funcionando bien? Este control exige mecanismos de medición continua, auditoría interna y un canal de rendición de cuentas ante las partes interesadas.

9.3. Controles seleccionados — ISO/IEC 27001:2022

De los 93 controles del Anexo A de la ISO/IEC 27001:2022, se seleccionaron cinco que, extendidos al contexto de IA, cubren los riesgos más críticos:

A.5.1- Políticas de seguridad de la información: las políticas de seguridad ya existentes en la mayoría de las organizaciones son el punto de partida natural. La extensión propuesta es simple pero importante: que esas políticas incluyan explícitamente los sistemas de IA como activos críticos. Se correlaciona con el requisito A.2 de la ISO/IEC 42001:2023 y la función GOVERN del NIST AI RMF 1.0.

A.8.8 - Gestión de vulnerabilidades técnicas: las organizaciones ya gestionan vulnerabilidades en sus sistemas convencionales. Lo que propone este trabajo es extender ese proceso a las librerías de machine learning, los frameworks de IA y las dependencias de terceros que conforman la cadena de suministro del modelo. Se correlaciona con el requisito A.4 de la ISO/IEC 42001:2023 y la función MAP del NIST AI RMF 1.0.

A.8.25 - Ciclo de vida de desarrollo seguro: DevSecOps para IA. Este control, pensado para software convencional, se extiende para incluir las fases de entrenamiento, validación y despliegue del modelo. Las pruebas de robustez adversarial y la validación de sesgos pasan a ser parte del proceso de desarrollo, no un anexo posterior. Se correlaciona con el requisito A.5 de la ISO/IEC 42001:2023 y las funciones MEASURE/MANAGE del NIST AI RMF 1.0.

A.5.23 - Seguridad en servicios en la nube: muchos modelos de IA corren sobre servicios de Machine Learning as a Service (MLaaS). Este control exige que esos servicios tengan requisitos de seguridad contractuales claros. Se correlaciona con el requisito A.7 de la ISO/IEC 42001:2023 y la función MANAGE del NIST AI RMF 1.0.

A.8.16 / A.5.2 — Monitoreo de actividades y roles: el A.8.16 monitorea comportamientos anómalos; extendido a IA, vigila la inferencia del modelo en busca de deriva o ataques. El A.5.2 asegura que haya alguien responsable de esa supervisión. Juntos, responden a la pregunta más básica: ¿quién cuida al modelo y cómo lo hace? Ambos se correlacionan con el requisito A.9 de la ISO/IEC 42001:2023 y la función GOVERN del NIST AI RMF 1.0

9.4. Mapping normativo — ¿Dónde se encuentran los tres marcos?

El resultado más importante del análisis es ver que los tres marcos, aunque llegaron por caminos distintos, terminan hablando de los mismos cinco problemas fundamentales. La Tabla 2 muestra esos puntos de encuentro:

ISO/IEC 42001:2023 — Anexo A	NIST AI RMF 1.0 — Función	ISO/IEC 27001:2022 — Control	¿En qué coinciden?
A.2 — Políticas para la IA	GOVERN	A.5.1 — Políticas de seguridad de la información	Los tres marcos piden que las reglas del juego estén escritas, aprobadas y conocidas por todos en la organización.
A.4 — Contexto de la organización	MAP	A.8.8 — Gestión de vulnerabilidades técnicas	Antes de encender el modelo, hay que saber en qué terreno opera: quiénes se afectan, qué fallas existen y qué riesgos trae consigo.
A.5 — Liderazgo y ciclo de vida	MEASURE / MANAGE	A.8.25 — Ciclo de vida de desarrollo seguro	La seguridad no empieza cuando el modelo sale a producción; los tres marcos exigen controles desde el primer día de diseño hasta el retiro del sistema.
A.7 — Operaciones de IA	MANAGE	A.5.23 / A.8.16 — Seguridad en servicios en la nube y monitoreo de actividades	Un modelo en producción debe vigilarse igual que cualquier activo crítico: si algo cambia en su comportamiento, la organización tiene que saberlo de inmediato.
A.9 — Evaluación del desempeño	GOVERN	A.5.2 — Roles y responsabilidades	Alguien tiene que responder por las decisiones que toma el sistema. Los tres marcos exigen que ese rol esté definido, asignado y activo.

Tabla 2 Mapping normativo entre los tres estándares

10. Resultados

10.1. El Framework IA-SEC

El resultado central de este trabajo es el Framework IA-SEC, un modelo de auditoría organizado en cuatro dominios que traducen los controles normativos en preguntas concretas que un auditor puede hacer a una organización. Los dominios no son independientes: se recorren en orden, porque cada uno construye sobre el anterior.

Dominio 1 - Gobernanza y Contexto de IA: el punto de partida. Antes de revisar cualquier aspecto técnico, hay que saber si la organización tiene claras las reglas:

¿existe una política de IA aprobada?, ¿hay alguien responsable de ella?, ¿se ha clasificado el riesgo del sistema? Correlacionado con GOVERN del NIST AI RMF 1.0, el requisito A.2 de la ISO/IEC 42001:2023 y el control A.5.1 de la ISO/IEC 27001:2022.

Dominio 2 - Ciclo de Vida del Modelo: ¿la seguridad estuvo presente desde que se diseñó el modelo o se agregó después? Este dominio revisa que cada fase del ciclo de vida — entrenamiento, validación, despliegue, retiro — haya tenido controles de seguridad integrados. Correlacionado con MEASURE/MANAGE del NIST AI RMF 1.0, el requisito A.5 de la ISO/IEC 42001:2023 y el control A.8.25 de la ISO/IEC 27001:2022.

Dominio 3 - Seguridad Técnica del Modelo: ¿el modelo puede ser engañado?, ¿sus APIs están protegidas?, ¿se probó contra ataques adversariales? Este dominio entra en la arquitectura técnica del sistema. Correlacionado con MAP del NIST AI RMF 1.0, el requisito A.4 de la ISO/IEC 42001:2023 y el control A.8.8 de la ISO/IEC 27001:2022.

Dominio 4 - Monitoreo Continuo: un modelo que nadie vigila es una amenaza latente. ¿Hay alertas configuradas para detectar deriva?, ¿el equipo sabe cuándo el modelo empieza a comportarse diferente? Este dominio cierra el ciclo. Correlacionado con MANAGE del NIST AI RMF 1.0, los requisitos A.7 y A.9 de la ISO/IEC 42001:2023 y los controles A.5.23, A.8.16 y A.5.2 de la ISO/IEC 27001:2022.

10.2. Lo que dijeron los expertos

Para validar que el modelo era útil en la práctica y no solo en el papel, se realizaron entrevistas estructuradas con tres perfiles de expertos simulados. Los hallazgos fueron consistentes:

Sobre la pertinencia de los controles: los tres perfiles coincidieron en que los cinco puntos de correlación cubren los riesgos más urgentes de IA en infraestructura crítica. El auditor líder destacó que reunir tres estándares en un solo instrumento ahorra tiempo y evita duplicar esfuerzos en la auditoría. El profesional de ciberseguridad señaló que los controles A.8.8 y A.8.16 son los que más falta hacen en los entornos productivos que conoce.

Sobre la escala de valoración: la escala de 0 a 5 fue bien recibida porque no solo dice si algo cumple o no cumple, sino dónde está la organización en su camino hacia el cumplimiento. Eso facilita priorizar qué arreglar primero.

Sobre las brechas del contexto colombiano: los tres perfiles señalaron lo mismo: Colombia no tiene regulación específica de IA en infraestructura crítica, y la función GOVERN es la que menos implementación real tiene. Las políticas de IA formales prácticamente no existen en el sector.

10.3. Lo que encontramos en cada punto de correlación

Correlación 1 - Gobernanza y políticas (A.2 / GOVERN / A.5.1): la mayoría de las organizaciones tienen políticas de seguridad, pero ninguna menciona la IA. La brecha no es técnica: es que nadie se ha sentado a actualizar el documento.

Correlación 2 - Contexto y vulnerabilidades (A.4 / MAP / A.8.8): los equipos de seguridad escanean servidores y aplicaciones, pero no las librerías de Python que usa el modelo ni las dependencias del pipeline de ML. Esa cadena de suministro está casi siempre ciega.

Correlación 3 - Ciclo de vida (A.5 / MEASURE-MANAGE / A.8.25): el modelo sale a producción después de pruebas funcionales, pero casi nunca después de pruebas de robustez adversarial o validación de sesgos. La seguridad llega tarde.

Correlación 4 - Operaciones y monitoreo (A.7 / MANAGE / A.5.23-A.8.16): los sistemas de monitoreo vigilan usuarios humanos, no modelos. Un modelo que está derivando pasa meses sin que nadie lo note, hasta que el daño ya está hecho.

Correlación 5 - Supervisión y rendición de cuentas (A.9 / GOVERN / A.5.2): en casi ninguna organización existe un responsable formal de los sistemas de IA. Las decisiones automatizadas ocurren, pero nadie responde por ellas institucionalmente.

11. Análisis Final

Después de cruzar los tres marcos y contrastar los hallazgos con los expertos, emergen tres conclusiones que van más allá de los controles individuales:

La brecha principal no es tecnológica. Las organizaciones de infraestructura crítica en Colombia ya tienen controles de seguridad. El problema es que esos controles fueron diseñados sin pensar en la IA. Actualizarlos no requiere comprar nuevas herramientas ni contratar más gente: requiere sentarse a redactar una política, asignar un rol y documentar lo que ya se hace. Es trabajo de escritorio, no de datacenter.

Sin gobernanza, todo lo demás falla. La función GOVERN del NIST AI RMF 1.0 resultó ser la más deficitaria en la práctica. Y no es casualidad: si no hay políticas claras sobre cómo se usa la IA, si nadie tiene asignada la responsabilidad de supervisarla, los controles técnicos de los otros dominios quedan sin respaldo institucional. El Dominio 1 del Framework IA-SEC no es el más espectacular, pero es el que sostiene todo lo demás.

El monitoreo en producción es la urgencia técnica más grande. Un modelo que nadie vigila es una amenaza que nadie va a detectar a tiempo. La deriva del modelo y los ataques adversariales son riesgos activos, no hipotéticos. Lo que propone el Framework IA-SEC en el Dominio 4 es exactamente lo que más falta hace hoy en las organizaciones colombianas de infraestructura crítica.

Desde la perspectiva regulatoria, Colombia está en un momento único. El CONPES 3995 ya reconoció la importancia de proteger la infraestructura crítica digital, y el EU AI Act está marcando el camino que el resto del mundo va a seguir. Las organizaciones que empiecen a implementar el Framework IA-SEC hoy no solo estarán cubriendo un riesgo real: estarán adelantándose a la regulación que inevitablemente llegará.

12. Conclusiones

Este trabajo partió de una pregunta concreta y llegó a una respuesta concreta. La pregunta era: ¿cómo audita un profesional de seguridad los sistemas de IA que operan en infraestructura crítica colombiana? La respuesta es el Framework IA-SEC.

1. Integrar el NIST AI RMF 1.0, la ISO/IEC 42001:2023 y la ISO/IEC 27001:2022 no solo es posible: es necesario. Ninguno de los tres es suficiente por sí solo. Los cinco puntos de correlación identificados muestran que los tres marcos convergen naturalmente en los mismos riesgos fundamentales de la IA.

2. La brecha más crítica en Colombia es organizacional, no tecnológica. Las organizaciones ya tienen herramientas; lo que falta es extenderlas hacia la IA mediante políticas, roles y procedimientos actualizados.

3. La gobernanza es el punto de partida no negociable. Sin políticas formales de IA y sin responsables institucionales claros, cualquier esfuerzo técnico queda sin sustento.

4. El monitoreo continuo en producción es la acción de mayor impacto inmediato. Implementar alertas para detectar deriva del modelo y comportamientos anómalos en la

inferencia puede marcar la diferencia entre detectar un problema a tiempo o descubrirlo cuando el daño ya es irreversible.

5. Colombia tiene una ventana de oportunidad. No existe aún una ley nacional sobre IA en infraestructura crítica, pero el EU AI Act muestra hacia dónde va el mundo. Las organizaciones que adopten el Framework IA-SEC hoy estarán mejor preparadas para cuando esa regulación llegue.

Este trabajo es un primer paso. Los siguientes serían validar el modelo en organizaciones reales, incorporar la regulación colombiana específica sobre IA cuando exista, y extender el Framework hacia sectores como telecomunicaciones y transporte. Pero ese primer paso era el que faltaba.

13. Definiciones

Auditoría de IA: proceso sistemático, independiente y documentado para evaluar el cumplimiento de sistemas de IA frente a criterios de seguridad, gobernanza y gestión de riesgos. (ISO/IEC 42001:2023, Cláusula 9.2)

Ciberseguridad: preservación de la confidencialidad, integridad y disponibilidad de la información, extendida en este trabajo a la protección de modelos de IA, datos de entrenamiento y APIs de inferencia. (ISO/IEC 27001:2022, Cláusula 3)

NIST AI RMF 1.0: marco voluntario del NIST que organiza la gestión de riesgos de IA en cuatro funciones — GOVERN, MAP, MEASURE y MANAGE. (NIST AI RMF 1.0, 2023)

ISO/IEC 42001:2023: primer estándar internacional certificable para establecer un Sistema de Gestión de Inteligencia Artificial (AIMS), con 38 controles específicos en su Anexo A.

ISO/IEC 27001:2022: estándar internacional para establecer un Sistema de Gestión de Seguridad de la Información (SGSI), extendido en este trabajo para cubrir activos específicos de IA.

Gobernanza de IA: conjunto de políticas, procesos, roles y responsabilidades para asegurar que el desarrollo y operación de sistemas de IA sea ético, transparente y auditable. (ISO/IEC 42001:2023, Cláusula 5 y NIST AI RMF 1.0, función GOVERN)

Infraestructura crítica: sistemas y activos vitales cuya incapacitación tendría un impacto debilitante sobre la seguridad nacional, la economía o la salud pública. Incluye los sectores financiero, energético y de salud en Colombia. (EU AI Act 2024, Anexo III y CONPES 3995)

Gestión de riesgos de IA: proceso continuo de identificación, análisis, evaluación y tratamiento de riesgos específicos de sistemas de IA, incluyendo ataques adversariales, envenenamiento de datos y deriva del modelo. (NIST AI RMF 1.0 e ISO/IEC 27005:2022)

Deriva del modelo (model drift): degradación gradual del rendimiento de un modelo de IA en producción debido a cambios en los datos de entrada o en el entorno operativo, que puede comprometer la confiabilidad y seguridad del sistema.

MLaaS (Machine Learning as a Service): modalidad de servicio en la nube que permite acceder a capacidades de machine learning sin infraestructura propia, introduciendo riesgos específicos en la cadena de suministro del modelo.

14. Lista de referencias

Consejo Nacional de Política Económica y Social. (2020). Documento CONPES 3995: Política Nacional de Confianza y Seguridad Digital. Departamento Nacional de Planeación. <https://colaboracion.dnp.gov.co/cdt/Conpes/Econ%C3%B3micos/3995.pdf>

European Parliament and the Council of the European Union. (2024). Artificial Intelligence Act. EUR-Lex. <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=celex:52021PC0206>

International Organization for Standardization. (2022). ISO/IEC 22989:2022. Information technology — Artificial intelligence — Artificial intelligence concepts and terminology. ISO. <https://www.iso.org/standard/74296.html>

International Organization for Standardization. (2022). ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements. ISO. <https://www.iso.org/standard/27001>

International Organization for Standardization. (2023). ISO/IEC 42001:2023. Information technology — Artificial intelligence — Management system. ISO. <https://www.iso.org/standard/81230.html>

National Institute of Standards and Technology. (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0). U.S. Department of Commerce.

<https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>

ISO (Organización Internacional de Normalización)

<https://www.iso.org/es/inteligencia-artificial>

Ministerio de Tecnologías de la Información y las Comunicaciones. (2022). Modelo de Seguridad y Privacidad de la Información — MSPI. MinTIC.

<https://www.mintic.gov.co/portal/inicio/Iniciativas/Gobierno-en-linea/MSPI/>

